

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

GRC Engineering (CGRCE) – Level 8

Course: GRC4992

Exam Phase: Phase 2

Exam Title: GRC Application and Professional Practice

Exam Guidelines & Description: This final examination assesses the student's ability to apply GRC principles in practical scenarios, navigate professional and ethical dilemmas, and demonstrate leadership in GRC implementation. The assessment emphasizes critical thinking, problem-solving, and the development of actionable GRC strategies in complex organizational contexts. Students are expected to integrate theoretical knowledge with practical application.

TIME ALLOWED: 3 Hours

TOTAL MARKS: 100 Marks

STATUS: Mandatory

INSTRUCTIONS TO CANDIDATES:

- 1 This paper consists of **THREE (3) SECTIONS**.
- 2 You are required to answer **ALL** questions in all sections.
- 3 Ensure your answers are grounded in **GRC best practices**, ethical considerations, and relevant industry standards (e.g., ISO 31000, COSO, ISACA, IIA).
- 4 Use real-world examples or hypothetical scenarios to support your arguments where appropriate.
- 5 **Academic Integrity:** This exam requires original reasoning. The use of generative AI for direct answers is strictly prohibited and will be detected through the requirement for specific architectural justifications and ethical reasoning.

SECTION A: GRC PROFESSIONAL PRACTICE & ETHICS (30 MARKS)

Question 1: The Ethical GRC Professional (15 Marks)

a) **Scenario:** You are the Chief GRC Officer (CGRCO) at *DataGuard Corp*, a company specializing in sensitive personal data processing. During a routine internal audit, you discover that a newly implemented AI-driven data analytics tool, while highly efficient, inadvertently uses a biased algorithm that disproportionately flags certain demographic groups for higher risk, leading to unfair treatment in credit scoring. The development team argues that the tool meets all technical specifications and improves overall efficiency.

Task: As the CGRCO, outline your ethical obligations and the steps you would take to address this situation. Discuss the potential legal, reputational, and ethical implications for DataGuard Corp if this bias is not rectified. Justify your actions based on professional GRC ethics and principles. (8 Marks)

b) **Task:** Discuss the concept of "**GRC Professional Independence**" and its importance in maintaining the integrity and effectiveness of a GRC program. Provide two distinct scenarios where a GRC professional's independence might be compromised, and for each, suggest practical strategies to mitigate the threat to independence. (7 Marks)

Question 2: Stakeholder Engagement & Communication (15 Marks)

a) **Scenario:** You are leading the GRC team at *MediCare Systems*, a healthcare technology provider. The company is undergoing a major regulatory audit (e.g., HIPAA, GDPR) that requires extensive documentation and evidence from various departments (IT, Legal, Operations). There is significant resistance from some department heads who view GRC as a bureaucratic burden.

Task: Develop a communication strategy to engage these reluctant stakeholders. Identify key messages, communication channels, and techniques you would employ to foster a collaborative environment and ensure timely submission of required information. Justify your approach based on effective stakeholder management principles in GRC. (8 Marks)

b) **Task:** Explain the critical role of "**Tone at the Top**" in establishing a strong GRC culture within an organization. Provide concrete examples of how senior leadership can actively demonstrate commitment to GRC, and discuss the consequences of a weak "Tone at the Top" on the overall GRC posture. (7 Marks)

SECTION B: GRC APPLICATION & IMPLEMENTATION (30 MARKS)

Question 3: Integrated GRC Frameworks (30 Marks)

a) **Scenario:** *OmniCorp*, a multinational conglomerate with diverse business units (e.g., manufacturing, retail, financial services), is struggling with siloed GRC efforts. Each business unit uses different risk assessment methodologies, compliance tools, and reporting structures, leading to inefficiencies, redundant controls, and a lack of enterprise-wide visibility into risk.

Task: As a GRC architect, propose an **integrated GRC framework** for OmniCorp. Your proposal should:

- * Identify a suitable overarching GRC framework (e.g., COSO, ISO 31000, NIST RMF) and justify its selection.
- * Outline how you would standardize risk assessment methodologies and control libraries across diverse business units.
- * Describe the key components of an integrated GRC technology solution that would support this framework, emphasizing interoperability and centralized reporting. (15 Marks)

b) **Task:** Discuss the challenges and benefits of implementing a "**Continuous Monitoring**" program for regulatory compliance in a large, complex organization like OmniCorp. Provide specific examples of technologies and processes that would enable continuous monitoring, and explain how it differs from traditional periodic audits. (15 Marks)

SECTION C: CASE STUDY – THE "QUANTUM LEAP" AI ETHICS DILEMMA (40 MARKS)

Case Background: *Quantum Leap Innovations* (QLI) is a leading AI development firm that has just launched "Aegis," an advanced AI system designed to predict and prevent cyberattacks with unprecedented accuracy. Aegis operates by continuously monitoring vast amounts of network traffic, user behavior, and external threat intelligence. While highly effective, concerns have emerged regarding Aegis's data collection practices, its potential for algorithmic bias in identifying "high-risk" individuals or organizations, and the lack of transparency in its decision-making processes. Regulators and privacy advocates are demanding greater accountability and ethical oversight of such powerful AI systems.

Question 4: Ethical AI Governance (15 Marks)

a) **Task:** As the Head of GRC at Quantum Leap Innovations (QLI), you are tasked with developing an **AI Governance Framework** for Aegis. Outline the key components of this framework, focusing on how it would address the concerns of algorithmic bias, data privacy, and transparency. Justify your framework by referencing relevant ethical AI principles and emerging AI regulations (e.g., EU AI Act, NIST AI Risk Management Framework). (8 Marks)

b) **Task:** QLI is facing public scrutiny regarding Aegis's data collection practices. Explain how a "**Privacy by Design**" approach could have been integrated into Aegis's development lifecycle to mitigate these concerns proactively. Provide specific examples of privacy-enhancing technologies or design choices that would demonstrate a commitment to data protection. (7 Marks)

Question 5: Risk Management in AI Systems (10 Marks)

a) **Task:** Conduct a qualitative risk assessment for QLI regarding the "**Algorithmic Bias**" identified in Aegis. Identify at least three potential impacts (e.g., reputational, financial, legal) and propose corresponding mitigation strategies from a GRC perspective. (10 Marks)

Question 6: Professional Practice & Accountability (15 Marks)

a) **Task:** QLI's board of directors is considering appointing an "**AI Ethics Officer**." Discuss the roles, responsibilities, and necessary qualifications for such a position within QLI. Explain how this role would integrate with the existing GRC structure and contribute to fostering a culture of responsible AI development. (7 Marks)

b) **Task:** Imagine you are presenting to the QLI board. Prepare a concise argument (maximum 200 words) on why investing in robust "**Explainable AI (XAI)**" capabilities for Aegis is not just a technical requirement but a strategic imperative for QLI's long-term success and ethical standing. (8 Marks)

END OF QUESTION PAPER